

DAMM v2 Release

0.1.7

Smart Contract Security Assessment

January 2026

Prepared for:

Meteora

Prepared by:

Offside Labs

Sirius Xie

Ronny Xing





Contents

1	About Offside Labs	2
2	Executive Summary	3
3	Summary of Findings	5
4	Key Findings and Recommendations	6
4.1	JUP_V6 Parameters and Accounts Manipulation	6
5	Disclaimer	8

DRAFT



1 About Offside Labs

Offside Labs is a leading security research team, composed of top talented hackers from both academia and industry.

We possess a wide range of expertise in modern software systems, including, but not limited to, *browsers*, *operating systems*, *IoT devices*, and *hypervisors*. We are also at the forefront of innovative areas like *cryptocurrencies* and *blockchain technologies*. Among our notable accomplishments are remote jailbreaks of devices such as the **iPhone** and **PlayStation 4**, and addressing critical vulnerabilities in the **Tron Network**.

Our team actively engages with and contributes to the security community. Having won and also co-organized *DEFCON CTF*, the most famous CTF competition in the Web2 era, we also triumphed in the **Paradigm CTF 2023** within the Web3 space. In addition, our efforts in responsibly disclosing numerous vulnerabilities to leading tech companies, such as *Apple*, *Google*, and *Microsoft*, have protected digital assets valued at over **\$300 million**.

In the transition towards Web3, Offside Labs has achieved remarkable success. We have earned over **\$9 million** in bug bounties, and **three** of our innovative techniques were recognized among the **top 10 blockchain hacking techniques of 2022** by the Web3 security community.



<https://offside.io/>



<https://github.com/offsidelabs>



https://twitter.com/offside_labs



2 Executive Summary

Introduction

Offside Labs completed a security audit of DAMM v2 smart contracts, starting on January 12th, 2026, and concluding on January 14th, 2026.

Project Overview

DAMM v2 Release 0.1.7 adds the `zap_protocol_fee` feature for protocol fee consolidation, allowing an operator to withdraw protocol fees to an operator receiving account and in the same transaction swap them via Zap and Jupiter Aggregator v6 or DAMM v2 before sending the proceeds to the treasury, while also introducing a whitelisted program mechanism to relax deep invocation limits under the rate limiter mode and updating operator permissions and related validation logic accordingly

Audit Scope

The assessment scope contains mainly the smart contracts of the cp-amm program for the DAMM v2 project.

The audit is based on the following specific branches and commit hashes of the codebase repositories:

- DAMM v2
 - Codebase: <https://github.com/MeteoraAg/damm-v2>
 - Release 0.1.7: [PR-167](#)
 - Commit Hash: `3ff06bd7d3e9c9a92348912e234ee66c7b633654`

The issues described in this report have been resolved by the following commit:

- DAMM v2
 - Codebase: <https://github.com/MeteoraAg/damm-v2>
 - Commit Hash: Commit

We listed the files we have audited below:

- DAMM v2 Release 0.1.7
 - `programs/cp-amm/src/access_control.rs`
 - `programs/cp-amm/src/const_pda.rs`
 - `programs/cp-amm/src/constants.rs`
 - `programs/cp-amm/src/entrypoint.rs`
 - `programs/cp-amm/src/error.rs`
 - `programs/cp-amm/src/instructions/admin/ix_close_operator_account.rs`
 - `programs/cp-amm/src/instructions/admin/ix_create_operator_account.rs`
 - `programs/cp-amm/src/instructions/ix_claim_position_fee.rs`
 - `programs/cp-amm/src/instructions/ix_claim_reward.rs`
 - `programs/cp-amm/src/instructions/ix_remove_liquidity.rs`



- programs/cp-amm/src/instructions/ix_withdraw_ineligible_reward.rs
- programs/cp-amm/src/instructions/operator/ix_claim_protocol_fee.rs
- programs/cp-amm/src/instructions/operator/ix_close_config.rs
- programs/cp-amm/src/instructions/operator/ix_close_token_badge.rs
- programs/cp-amm/src/instructions/operator/ix_create_dynamic_config.rs
- programs/cp-amm/src/instructions/operator/ix_create_static_config.rs
- programs/cp-amm/src/instructions/operator/ix_create_token_badge.rs
- programs/cp-amm/src/instructions/operator/ix_set_pool_status.rs
- programs/cp-amm/src/instructions/operator/ix_update_pool_fees.rs
- programs/cp-amm/src/instructions/operator/zap_protocol_fee/damm_v2_zap.rs
- programs/cp-amm/src/instructions/operator/zap_protocol_fee/jup_v6_zap.rs
- programs/cp-amm/src/instructions/operator/zap_protocol_fee/process_zap_protocol_fee.rs
- programs/cp-amm/src/instructions/partner/ix_claim_partner_fee.rs
- programs/cp-amm/src/instructions/swap/ix_p_swap.rs
- programs/cp-amm/src/instructions/swap/ix_swap.rs
- programs/cp-amm/src/lib.rs
- programs/cp-amm/src/macros.rs
- programs/cp-amm/src/math/safe_math.rs
- programs/cp-amm/src/state/operator.rs
- programs/cp-amm/src/utils/token.rs

Findings

The security audit revealed:

- 0 critical issue
- 0 high issue
- 1 medium issue
- 0 low issue
- 0 informational issue

Further details, including the nature of these issues and recommendations for their remediation, are detailed in the subsequent sections of this report.



3 Summary of Findings

ID	Title	Severity	Status
01	JUP_V6 Parameters and Accounts Manipulation	Medium	Acknowledged

DRAFT



4 Key Findings and Recommendations

4.1 JUP_V6 Parameters and Accounts Manipulation

Severity: Medium

Status: Acknowledged

Target: Smart Contract

Category: Logic Error

Description

Parameter `route_plan` :

In the `zap_protocol_fee` instruction, if a `zap_out` is performed via JUP_V6's `route_*` / `shared_account_route_*`, the program does not validate the `route_plan` in the Jupiter aggregator instruction parameters.

Scenario 1: The input is not fully consumed

The program cannot guarantee that the `route_plan` will consume 100% of the `input_mint` during the Jupiter aggregator route swap. During Jupiter's `execute_route_plan` flow (including all instructions that use this method), there is also no check that the provided `route_plan` fully consumes the `input_mint`.

Scenario 2: The output is not fully deposited into the treasury

The program cannot guarantee that the outputs from all intermediate swap steps will ultimately be consolidated into the treasury's token account.

Given that the slippage-related parameters of the instruction are also fully controllable, if `minimum_output` is set to 0, any amount of output mint received by the treasury can pass the slippage check.

Parameter `platform_fee_bps` & Account `platform_fee_account` :

There is also no check on the relationship between `platform_fee_bps` and 0, nor any check that `platform_fee_account` is a trusted token account. If `platform_fee_bps` is greater than 0, this could result in a portion of the `protocol_fee` being transferred to an untrusted `platform_fee_account`.

Impact

A malicious operator could craft a malicious `route_plan` and `platform_fee_bps` & `platform_fee_account` to steal protocol fees.

Recommendation

In `zap_protocol_fee`, ensure that all `protocol_fee` amounts are fully swapped via the JUP_V6-related instructions, and require that 100% of all intermediate swap outputs in the `route_plan` are consolidated into the final `output_token_account`.



For the platform fee-related inputs, you can require `platform_fee_bps` to be 0 or within a reasonable range. When `platform_fee_bps > 0`, ensure that `platform_fee_account` is a trusted token account.

Mitigation Review Log

Meteora Team: We will fix that in other release since it is permissioned action, but for current release, we will ACK that.

DRAFT



5 Disclaimer

This audit report is provided for informational purposes only and is not intended to be used as investment advice. While we strive to thoroughly review and analyze the smart contracts in question, we must clarify that our services do not encompass an exhaustive security examination. Our audit aims to identify potential security vulnerabilities to the best of our ability, but it does not serve as a guarantee that the smart contracts are completely free from security risks.

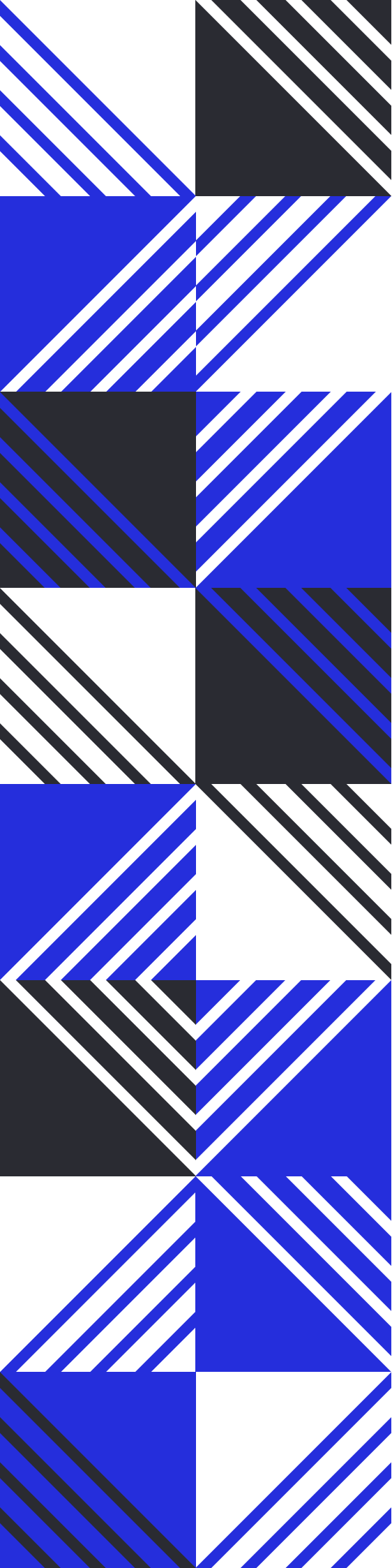
We expressly disclaim any liability for any losses or damages arising from the use of this report or from any security breaches that may occur in the future. We also recommend that our clients engage in multiple independent audits and establish a public bug bounty program as additional measures to bolster the security of their smart contracts.

It is important to note that the scope of our audit is limited to the areas outlined within our engagement and does not include every possible risk or vulnerability. Continuous security practices, including regular audits and monitoring, are essential for maintaining the security of smart contracts over time.

Please note: we are not liable for any security issues stemming from developer errors or misconfigurations at the time of contract deployment; we do not assume responsibility for any centralized governance risks within the project; we are not accountable for any impact on the project's security or availability due to significant damage to the underlying blockchain infrastructure.

By using this report, the client acknowledges the inherent limitations of the audit process and agrees that our firm shall not be held liable for any incidents that may occur subsequent to our engagement.

This report is considered null and void if the report (or any portion thereof) is altered in any manner.



 <https://offside.io/>

 <https://github.com/offsidelabs>

 https://twitter.com/offside_labs